

AbangCebu AI — Authentication Test Plan & Test Scenarios

Document Version: 1.0.0
Document Status: Approved Test Specification (Pre-Implementation)
Execution Phase: Pending Feature Development (Sprint 2 Execution)
Jira Ticket References: [SCRUM-69](#), [SCRUM-109](#) (Master Plan), [SCRUM-110](#) (Registration), [SCRUM-111](#) (Login), [SCRUM-112](#) (Reset & Sign-Out) **Sprint:** Sprint 1 (Foundations & Core Infrastructure)
Author: Jenny Villamor (QA Team)
Reviewed & Audited by: Hermar Centillas (Lead / Scrum Master)
Deliverable Excel Companion: `docs/testing/AbangCebu_Auth_Test_Specification.xlsx`
Related Specifications: - User Registration Specification: [docs/specifications/auth/auth-registration-spec.md](#) - User Login & Session Token Lifecycle: [docs/specifications/auth/auth-session-lifecycle.md](#) - User Logout & Session Invalidation: [docs/specifications/auth/auth-logout-spec.md](#) - Password Reset & Recovery Specification: [docs/specifications/auth/auth-password-reset-spec.md](#) - Error Handling & Edge Cases Specification: [docs/specifications/auth/auth-error-handling.md](#) - Users & Profiles Table Schema: [docs/database/users-and-profiles-schema.md](#) - TypeScript Authentication Definitions: [src/types/auth.ts](#)

1. Executive Summary & Test Strategy

1.1 Purpose

This QA Test Plan establishes a formal, production-grade quality assurance framework for the entire authentication and identity lifecycle of AbangCebu AI. It guarantees that all authentication pathways—registration, email verification, login, session token rotation, multi-tab invalidation, self-service password recovery, and error handling—are rigorously validated against security standards, edge-case resilience, and user acceptance criteria prior to UI integration.

1.2 Test Scope Boundaries

- **In Scope:**
 - Client and server-side request/response data contract validation (`src/types/auth.ts`).
 - Anti-privilege escalation defenses (preventing unauthorized self-assignment of `admin` role).
 - NIST SP 800-63B password complexity and Philippine mobile number E.164 normalization (`+639XXXXXXXX`).
 - Supabase GoTrue PKCE email verification and password reset code exchanges.
 - HTTP-only cookie security flags, cookie chunking (>4096 bytes), and zeroing protocols (`Max-Age=0`).
 - Refresh Token Rotation (RTR) 30-second concurrency grace periods and token family reuse detection.
 - Cross-tab sign-out synchronization via HTML5 `BroadcastChannel('supabase.auth.token')` .
 - Immediate session termination and route blocking for suspended accounts (`profiles.is_suspended = true`).
 - Anti-enumeration response neutrality and rolling rate limiters.
- **Out of Scope for Sprint 1:**
 - Interactive UI button renders, React form animations, and visual styling mockups (governed separately under Sprint 2).

1.3 Test Environment & Tooling

- **Test Runner:** Vitest + Playwright (Headless API testing).
- **Database:** Local/Staging Supabase PostgreSQL 15+ container with GoTrue Auth and PostGIS enabled.
- **Network Mocking:** MSW (Mock Service Worker) for simulating intermittent transit connectivity and timeout drops.

2. Test Classification & Methodology

+-----+ TESTING METHODOLOGY MATRIX	
---	--

Test Level	Primary Focus	Method & Automation Approach
Unit Testing (UT)	Functions & Types	Validates input regex, NIST password validator, phone normalizer, and error factory methods in src/types/
Integration (IT)	API Handlers & DB	Validates Route Handlers (/api/auth/*), Supabase cookie mutations, and PostgreSQL trigger execution
Security & E2E (ST)	Auth Lifecycle & Anti-Abuse	Verifies multi-tab broadcast, token reuse lockout, rate limits, anti-enumeration, and account suspension

3. Preconditions & Test Data Setup

Entity / Account	Role	Credentials	Initial Account State
Renter 1 (Active)	renter	mika.cebu@example.com / ValidP@ssw0rd2026!	Email confirmed, is_suspended = false
Renter 2 (Unconfirmed)	renter	unconfirmed.renter@example.com / ValidP@ssw0rd2026!	Email unconfirmed (email_confirmed_at = null)
Landlord 1 (Active)	landlord	carlos.landlord@example.com / ValidLandlord2026#	Email confirmed, KYC pending, active session
Landlord 2 (Suspended)	landlord	scammer.landlord@example.com / ValidLandlord2026#	Email confirmed, is_suspended = true
Rate Limit Test Target	guest	spam.tester@example.com / AnyPassword123!	IP/Email rate-limit test subject

4. Master QA Test Case Execution Matrix (100 Scenarios)

Suite 1: User Registration & PKCE Verification (25 Scenarios) ([SCRUM-110](#))

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-REG-01	Registration - Valid Renter	1. Submit RegisterPayload with valid email, NIST-compliant password, role='renter', and phone '09171234567'. 2. Call registration Route Handler.	1. HTTP 200/201 response. 2. Phone normalized to canonical +639171234567. 3. Profile row created in public.profiles via handle_new_user() trigger. 4. Verification email dispatched.	Pending Dev	P0 (Critical)
TC-REG-02	Registration - Valid Landlord	1. Submit RegisterPayload with role='landlord', valid credentials, and preferred landmark. 2. Execute registration Route Handler.	1. User created with role='landlord'. 2. Response directs to /landlord/onboarding. 3. Landlord onboarding profile record initialized.	Pending Dev	P0 (Critical)
TC-REG-03	Registration - Anti-Privilege Escalation	1. Submit payload attempting role='admin'. 2. Validate TypeScript contract, Route Handler validation, and database trigger.	1. Contract rejects payload with INVALID_ROLE. 2. If bypassed via raw HTTP, server returns HTTP 403 PRIVILEGE_ESCALATION_ATTEMPT. 3. DB trigger enforces fallback to 'renter'.	Pending Dev	P0 (Critical)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-REG-04	Registration - Weak Password Rejection	1. Attempt registration with password < 8 chars ('Ab1!'). 2. Attempt password missing special character ('Password123'). 3. Attempt password exceeding 72 chars.	1. Request rejected with HTTP 422 WEAK_PASSWORD. 2. Response details specifies exact unmet NIST criteria. 3. Zero user records created.	Pending Dev	P1 (High)
TC-REG-05	Registration - Invalid Philippine Phone Rejection	1. Attempt registration with non-PH numbers ('+1234567890', '08123456789', '12345').	1. Validation fails with HTTP 422 INVALID_PHONE_NUMBER. 2. Field error explicitly states requirement for 09XXXXXXXXXX format.	Pending Dev	P1 (High)
TC-REG-06	Registration - Duplicate Email Handling	1. Submit registration payload using an existing email address ('mika.cebuh@example.com').	1. Anti-enumeration defense preserves privacy. 2. Dispatches password reset notification to the owner without revealing account collision to scraper.	Pending Dev	P1 (High)
TC-REG-07	Registration - Turnstile Bot Verification Failure	1. Submit registration request with missing or invalid turnstileToken.	1. Request immediately rejected with HTTP 400 CAPTCHA_VERIFICATION_FAILED. 2. Zero database queries executed.	Pending Dev	P1 (High)
TC-REG-08	Registration - Duplicate Phone Collision	1. Submit registration payload using an already registered Philippine phone number with a new email.	1. Validation catches phone uniqueness conflict. 2. Returns HTTP 409 PHONE_ALREADY_REGISTERED with user-safe message.	Pending Dev	P1 (High)
TC-REG-09	Registration - SQL & Script Injection Sanitization	1. Enter full_name containing XSS payload: " or SQL fragment "' OR 1=1 --".	1. Payload is fully parameterized and sanitized. 2. Stored string has tags stripped or HTML escaped. 3. Zero script execution.	Pending Dev	P0 (Critical)
TC-REG-10	Registration - Email Whitespace & Case Normalization	1. Submit email with leading/trailing spaces and mixed case: 'Mika.Cebuh@Example.COM '.	1. Email normalized to lowercase trimmed 'mika.cebuh@example.com'. 2. Stored in canonical form in auth.users.	Pending Dev	P2 (Medium)
TC-REG-11	Registration - Password Confirmation Mismatch	1. Enter valid password in primary field and differing string in confirm_password field.	1. Client validator blocks submission with inline error. 2. If submitted via API, server returns HTTP 422 PASSWORD_CONFIRMATION_MISMATCH.	Pending Dev	P1 (High)
TC-REG-12	Registration - Missing Mandatory Fields	1. Submit JSON payload omitting full_name or role field.	1. Server returns HTTP 422 VALIDATION_ERROR. 2. details array contains field-specific path and failure code.	Pending Dev	P1 (High)
TC-REG-13	Registration - Rapid Multi-Click Debounce	1. Rapidly trigger registration submit button 5 times within 300ms.	1. Client disables submit button immediately after first click. 2. API receives only single registration dispatch.	Pending Dev	P2 (Medium)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-REG-14	Registration - Atomic Transaction Rollback on Failure	1. Simulate database failure during profile creation trigger after auth.users insertion.	1. Database transaction rolls back atomically. 2. Zero orphaned records left in auth.users or public.profiles.	Pending Dev	P0 (Critical)
TC-REG-15	Registration - PKCE Activation Email Dispatch	1. Complete valid registration. 2. Inspect outbound transactional email dispatch payload.	1. Email queued with single-use PKCE verification token. 2. Redirect URL targets canonical /auth/callback with type=signup.	Pending Dev	P0 (Critical)
TC-REG-16	Verification - Valid PKCE Code Exchange	1. User clicks confirmation link GET /auth/callback?code=VALID_CODE&type=signup. 2. Next.js Route Handler exchanges code via @supabase/ssr.	1. auth.users.email_confirmed_at timestamp set. 2. Authenticated session cookies issued (Set-Cookie). 3. Redirects safely to /search (Renter) or /landlord/onboarding (Landlord).	Pending Dev	P0 (Critical)
TC-REG-17	Verification - Expired Confirmation Code	1. User clicks confirmation link after 24 hours (code=EXPIRED_CODE).	1. Route Handler catches Supabase exchange error. 2. Redirects to /login?error=confirmation_expired. 3. UI displays persistent banner with resend CTA.	Pending Dev	P1 (High)
TC-REG-18	Verification - Tampered / Corrupted PKCE Code	1. Submit request with corrupted code code=INVALID_12345.	1. Exchange fails. 2. Redirects to /login?error=invalid_confirmation_link. 3. Zero session cookies issued.	Pending Dev	P1 (High)
TC-REG-19	Verification - Single-Use Code Replay Invalidation	1. Click confirmation link once (succeeds). 2. Attempt to exchange the identical confirmation link a second time.	1. Second exchange fails. 2. User redirected to /login with notification that link was already used.	Pending Dev	P1 (High)
TC-REG-20	Verification - Open-Redirect Protection on Callback	1. User clicks link containing open-redirect injection: ?next=https://attacker-cebu.com.	1. isSafeRedirectUrl() flags external protocol. 2. Destination sanitized and forced to default internal path (/search or /dashboard).	Pending Dev	P0 (Critical)
TC-REG-21	Verification - Post-Activation Role-Based Routing	1. Complete PKCE confirmation for Renter user. 2. Complete PKCE confirmation for Landlord user.	1. Renter is routed to catalog search / search. 2. Landlord is routed to landlord KYC onboarding /landlord/onboarding.	Pending Dev	P0 (Critical)
TC-REG-22	Registration - Unactivated Account Login Prevention	1. Attempt to log in with newly registered credentials before clicking email activation link.	1. Login rejected with HTTP 403 AUTH_EMAIL_NOT_CONFIRMED. 2. UI displays banner prompt to check inbox for verification email.	Pending Dev	P1 (High)
TC-REG-23	Registration - Terms of Service Acceptance Requirement	1. Submit registration payload with terms_accepted=false or omitted.	1. Form submission rejected with HTTP 422 TERMS_REQUIRED. 2. Inline error indicates Terms and Privacy Policy must be accepted.	Pending Dev	P1 (High)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-REG-24	Registration - Unicode & Philippine Character Support	1. Register with full_name containing Philippine characters: 'José Peña Niño'.	1. Registration succeeds. 2. Name stored and retrieved with exact UTF-8 character encoding.	Pending Dev	P2 (Medium)
TC-REG-25	Registration - Concurrent Registration Race Handling	1. Submit two simultaneous registration requests with identical email from two different network threads.	1. Exactly one registration succeeds. 2. Second request handled gracefully via unique constraint without crashing.	Pending Dev	P1 (High)

Suite 2: User Login & Session Token Lifecycle (25 Scenarios) ([SCRUM-111](#))

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-LOG-01	Login - Valid Renter Authentication	1. Submit valid Renter credentials ('mika.cebu@example.com'). 2. Call login Route Handler.	1. HTTP 200 response. 2. HTTP-only session cookies set (sb-*-auth-token, HttpOnly=true, Secure=true, SameSite=lax). 3. Redirect target resolved to /search.	Pending Dev	P0 (Critical)
TC-LOG-02	Login - Valid Landlord Authentication	1. Submit valid Landlord credentials ('carlos.landlord@example.com').	1. HTTP 200 response. 2. Session cookies set. 3. Redirect target resolved to /landlord/dashboard.	Pending Dev	P0 (Critical)
TC-LOG-03	Login - Valid Admin Authentication	1. Submit internal administrator credentials ('admin@abangcebu.internal').	1. HTTP 200 response. 2. Admin session cookies established. 3. Redirect target resolved to /admin.	Pending Dev	P0 (Critical)
TC-LOG-04	Login - Invalid Password Rejection	1. Submit valid email with incorrect password. 2. Repeat 3 times.	1. Request rejected with HTTP 401 AUTH_INVALID_CREDENTIALS. 2. Generic message: 'Invalid email or password.' 3. Zero session cookies set.	Pending Dev	P0 (Critical)
TC-LOG-05	Login - Non-Existent User Rejection	1. Submit non-existent email address ('ghost@example.com') with arbitrary password.	1. Request rejected with HTTP 401 AUTH_INVALID_CREDENTIALS. 2. Identical error copy to TC-LOG-04 preventing user enumeration.	Pending Dev	P0 (Critical)
TC-LOG-06	Login - Unconfirmed Email Login Block	1. Attempt login using 'unconfirmed.renter@example.com'.	1. Request rejected with HTTP 403 AUTH_EMAIL_NOT_CONFIRMED. 2. UI instructs user to verify email before accessing account with resend link.	Pending Dev	P1 (High)
TC-LOG-07	Login - Suspended User Login Interception	1. Attempt login with suspended user credentials ('scammer.landlord@example.com').	1. Authentication fails with HTTP 403 AUTH_ACCOUNT_SUSPENDED. 2. Edge Middleware immediately blocks session creation. 3. UI directs user to /suspended with support appeal instructions.	Pending Dev	P0 (Critical)
TC-LOG-08	Login - Remember Me Active (30-Day Cookie)	1. Submit valid login with remember_me=true.	1. Session cookies emitted with Max-Age=2592000 (30 days). 2. Expires attribute explicitly set to 30 days in future.	Pending Dev	P1 (High)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-LOG-09	Login - Remember Me Inactive (Session Cookie)	1. Submit valid login with remember_me=false.	1. Session cookies emitted without explicit Max-Age. 2. Cookies expire upon browser process termination.	Pending Dev	P1 (High)
TC-LOG-10	Login - Cookie Chunking (>4096 Bytes)	1. Authenticate user with extensive profile metadata triggering serialized cookie payload > 4KB.	1. @supabase/ssr chunks session across sb--auth-token.0, sb--auth-token.1. 2. Middleware successfully reconstructs session without hydration drop.	Pending Dev	P1 (High)
TC-LOG-11	Login - Refresh Token Rotation (RTR)	1. Present active refresh token to obtain fresh 1-hour JWT access token.	1. New JWT issued. 2. Old refresh token invalidated; new single-use refresh token returned. 3. 30-second concurrency grace period active.	Pending Dev	P0 (Critical)
TC-LOG-12	Login - RTR Concurrency Grace Window	1. Fire two concurrent token refresh requests within 3 seconds using the same refresh token.	1. Both requests succeed within the 30-second grace window. 2. Client receives valid rotated session without abrupt logout.	Pending Dev	P0 (Critical)
TC-LOG-13	Login - Token Family Reuse Detection & Lockout	1. Malicious actor re-submits a previously rotated (revoked) refresh token after 30s grace window.	1. Supabase GoTrue flags token family reuse. 2. Entire token family instantly revoked. 3. All active sessions for user terminated with HTTP 401 AUTH_REFRESH_TOKEN_REUSED.	Pending Dev	P0 (Critical)
TC-LOG-14	Login - Philippine Phone Number Login	1. Submit phone number '09171234567' and valid password.	1. Phone normalized to +639171234567. 2. User successfully authenticated and session issued.	Pending Dev	P1 (High)
TC-LOG-15	Login - Password Masking & Input Type Verification	1. Inspect password input element on login form.	1. Field has type='password'. 2. Toggle button reveals password in plaintext with accessible aria-label. 3. Form auto-submits over TLS (HTTPS).	Pending Dev	P2 (Medium)
TC-LOG-16	Login - Brute Force Rate Limiting (5 Attempts)	1. Submit 5 invalid passwords consecutively from same IP within 15 minutes.	1. 6th attempt rejected with HTTP 429 RATE_LIMIT_EXCEEDED. 2. Ephemeral toast displays retry-after cooldown countdown.	Pending Dev	P0 (Critical)
TC-LOG-17	Login - Return URL Redirection (?next=)	1. Access protected route /saved while unauthenticated. 2. Redirected to /login?next=/saved. 3. Submit valid credentials.	1. After successful authentication, user is redirected to /saved instead of default role dashboard.	Pending Dev	P1 (High)
TC-LOG-18	Login - Open-Redirect Defense on Return URL	1. Access /login?next=https://malicious-site.com. 2. Authenticate successfully.	1. isSafeRedirectUrl() flags external protocol. 2. User redirected safely to default role landing page (/search or /dashboard).	Pending Dev	P0 (Critical)
TC-LOG-19	Login - Session Re-Authentication Prompt	1. Attempt sensitive action (e.g. payout bank details edit) after 30 minutes of idle session.	1. Re-auth modal displayed. 2. Action proceeds only upon password re-verification.	Pending Dev	P1 (High)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-LOG-20	Login - Trailing Whitespace in Login Identifier	1. Enter email 'mika.cebu@example.com ' with valid password.	1. Identifier trimmed client-side and server-side. 2. Login succeeds seamlessly.	Pending Dev	P2 (Medium)
TC-LOG-21	Login - Client State Synchronization Upon Login	1. Log in on Tab A while Tab B is open on public landing page.	1. Tab A logs in. 2. Tab B detects session establishment via BroadcastChannel and updates header state to show user avatar.	Pending Dev	P1 (High)
TC-LOG-22	Login - Expired JWT Access Token Renewal	1. Simulate expired 1-hour JWT. 2. Next.js Server Component executes fetch request.	1. Middleware transparently rotates token. 2. Fresh JWT returned without disrupting user view.	Pending Dev	P0 (Critical)
TC-LOG-23	Login - Empty Credentials Validation	1. Submit login form with empty email and password fields.	1. Form displays inline validation errors for both fields. 2. Zero network requests dispatched.	Pending Dev	P2 (Medium)
TC-LOG-24	Login - Network Disconnection During Login Request	1. Simulate offline state (navigator.onLine=false) right upon submitting login credentials.	1. Client displays toast: 'Network connection lost. Please check your connection and retry.' 2. User input preserved in form fields.	Pending Dev	P1 (High)
TC-LOG-25	Login - Audit Logging of Successful & Failed Logins	1. Execute 1 successful and 1 failed login attempt. 2. Inspect auth audit log records.	1. Both events recorded with timestamp, masked identifier, IP hash, and status. 2. Complies with RA 10173 data privacy rules.	Pending Dev	P1 (High)

Suite 3: Self-Service Password Recovery (15 Scenarios) ([SCRUM-112](#))

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-RST-01	Password Reset - Valid Recovery Request	1. Submit valid email to POST /api/auth/reset-password/request.	1. HTTP 200 response. 2. Generic message: 'If an account is associated with this email, a recovery link has been dispatched.' 3. Single-use PKCE link sent.	Pending Dev	P0 (Critical)
TC-RST-02	Password Reset - Anti-Enumeration for Non-Existent Email	1. Submit unregistered email ('nonexistent.user@example.com').	1. HTTP 200 response. 2. Message and timing match TC-RST-01 identically (artificial 200-400ms jitter applied). 3. Zero account existence disclosure.	Pending Dev	P0 (Critical)
TC-RST-03	Password Reset - Rate Limiting (3 in 15 mins)	1. Submit 4 password reset requests within a 15-minute rolling window for the same email.	1. Requests 1–3 succeed. 2. Request 4 rejected with HTTP 429 AUTH_PASSWORD_RESET_RATE_LIMIT.	Pending Dev	P1 (High)
TC-RST-04	Password Reset - Valid Recovery Link Exchange	1. User clicks email link GET /auth/callback?code=RECOVERY_CODE&type=recovery. 2. Route Handler exchanges code.	1. Temporary recovery session established. 2. Redirects to /reset-password. 3. Session limited strictly to password update actions.	Pending Dev	P0 (Critical)
TC-RST-05	Password Reset - Expired Recovery Token Link (>60 mins)	1. User clicks recovery link after 60 minutes.	1. Token exchange rejected. 2. Redirects to /login?error=recovery_link_expired. 3. UI displays banner prompt to request fresh reset link.	Pending Dev	P1 (High)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-RST-06	Password Reset - Single-Use Token Replay Invalidation	1. Successfully use recovery link to reach /reset-password. 2. Attempt to open identical link again.	1. Second exchange rejected. 2. Token marked consumed.	Pending Dev	P1 (High)
TC-RST-07	Password Reset - NIST Password Complexity Validation	1. In /reset-password, enter weak new password ('short'). 2. Submit update.	1. Rejected with HTTP 422 WEAK_PASSWORD. 2. Inline checklist highlights missing 8-character and character-class criteria.	Pending Dev	P1 (High)
TC-RST-08	Password Reset - Password Confirmation Mismatch	1. Enter valid new password and non-matching confirm password.	1. Client validator blocks submission. 2. Server returns HTTP 422 PASSWORD_CONFIRMATION_MISMATCH.	Pending Dev	P1 (High)
TC-RST-09	Password Reset - Successful Update & Hash Commit	1. Submit valid NIST-compliant new password.	1. Password hash updated in auth.users. 2. Success response returned. 3. User redirected to /login?message=password_reset_success.	Pending Dev	P0 (Critical)
TC-RST-10	Password Reset - Mandatory Global Revocation	1. User updates password in Browser A. 2. Attempt API request in Browser B with pre-existing session.	1. Supabase executes signOut({ scope: 'global' }). 2. Browser B session immediately invalidated (HTTP 401). 3. Old refresh tokens completely dead.	Pending Dev	P0 (Critical)
TC-RST-11	Password Reset - Cookie Purging on Reset Success	1. Inspect Set-Cookie headers upon password reset completion.	1. All session and recovery cookies purged with Max-Age=0. 2. Forces clean login with new credentials.	Pending Dev	P1 (High)
TC-RST-12	Password Reset - Previous Password Reuse Prevention	1. Attempt to set new password identical to current existing password.	1. Server rejects with HTTP 422 PASSWORD_REUSE_FORBIDDEN. 2. Prompt suggests choosing a distinct password.	Pending Dev	P2 (Medium)
TC-RST-13	Password Reset - Suspended Account Reset Block	1. Request password reset for an account currently flagged profiles.is_suspended=true.	1. Generic notice displayed to requester (anti-enumeration). 2. Recovery email suppressed or contains suspension support notification.	Pending Dev	P1 (High)
TC-RST-14	Password Reset - Open-Redirect Guard on Recovery Callback	1. Access recovery callback with ?next=https://phishing-site.com.	1. isSafeRedirectUrl() strips external domain. 2. Safely routes to /reset-password.	Pending Dev	P0 (Critical)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-RST-15	Password Reset - Security Audit Log Emission	1. Complete successful password reset. 2. Query auth security audit logs.	1. Event PASSWORD_RESET_COMPLETED recorded with timestamp and masked identifier. 2. Notification email sent to user confirming password change.	Pending Dev	P1 (High)

Suite 4: User Sign-Out & Multi-Tab Synchronization (15 Scenarios) ([SCRUM-112](#))

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-OUT-01	Sign-Out - Local Device Invalidation (scope: 'local')	1. Authenticated user triggers Sign Out. 2. Execute signOutAction({ scope: 'local' }).	1. Current session deleted in auth.sessions. 2. Set-Cookie emits Max-Age=0 and past epoch for all cookie chunks. 3. Remote sessions on other devices remain active.	Pending Dev	P0 (Critical)
TC-OUT-02	Sign-Out - Global Multi-Device Invalidation (scope: 'global')	1. User selects 'Log out of all devices'. 2. Execute signOutAction({ scope: 'global' }).	1. All rows for user_id purged from auth.sessions. 2. All refresh token families revoked. 3. All sessions across all devices terminated.	Pending Dev	P0 (Critical)
TC-OUT-03	Sign-Out - Multi-Chunk Cookie Zeroing (sb-*-auth-token.0..N)	1. User with chunked cookies (.0, .1) triggers logout.	1. Response emits Set-Cookie for base name and all chunk indices with Max-Age=0 and Expires=1970. 2. Client cookie jar completely wiped.	Pending Dev	P0 (Critical)
TC-OUT-04	Sign-Out - BroadcastChannel Multi-Tab Synchronization	1. User opens Tab A and Tab B while logged in. 2. User clicks Sign Out in Tab A.	1. Tab A executes logout and posts SIGNED_OUT to BroadcastChannel('supabase.auth.token'). 2. Tab B receives message, purges local cache, and redirects to /login? reason=signed_out.	Pending Dev	P0 (Critical)
TC-OUT-05	Sign-Out - In-Memory State & React Query Cache Flush	1. Inspect TanStack Query / SWR cache and user profile store immediately following logout.	1. All user query keys evicted and reset to empty state. 2. Zero residual cached user data in browser memory.	Pending Dev	P0 (Critical)
TC-OUT-06	Sign-Out - Router Cache Purge & Back Button Guard	1. User logs out from / dashboard. 2. User clicks browser 'Back' button.	1. Next.js router.refresh() purges client RSC payload cache. 2. Protected route headers (Cache-Control: no-store) force server re-evaluation. 3. Middleware blocks access with HTTP 307 to /login.	Pending Dev	P0 (Critical)
TC-OUT-07	Sign-Out - Offline Logout Fallback Resilience	1. Disconnect network (navigator.onLine = false). 2. User triggers Sign Out.	1. Optimistic local cookie destruction executes. 2. Memory credentials flushed. 3. UI navigates safely to unauthenticated landing page.	Pending Dev	P1 (High)
TC-OUT-08	Sign-Out - Security Response Header Emission	1. Inspect HTTP response headers of POST /api/auth/logout.	1. Headers contain Clear-Site-Data: 'cache', 'cookies', 'storage'. 2. Cache-Control: no-store, no-cache, must-revalidate enforced.	Pending Dev	P1 (High)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-OUT-09	Sign-Out - Modal Confirmation Flow	1. User clicks 'Sign Out' in avatar menu. 2. In confirmation modal, click 'Cancel'.	1. Modal closes. 2. User session remains fully active with zero cookie mutations.	Pending Dev	P2 (Medium)
TC-OUT-10	Sign-Out - Post-Logout Redirect Destination	1. Complete sign-out from /landlord/dashboard.	1. User redirected to /login?reason=signed_out. 2. Toast/Banner confirms successful logout.	Pending Dev	P1 (High)
TC-OUT-11	Sign-Out - Stale Token Rejection After Logout	1. Capture JWT before logout. 2. Perform logout. 3. Attempt to use captured JWT in Authorization header for protected API.	1. API rejects request with HTTP 401 Unauthorized. 2. GoTrue session invalidation confirmed.	Pending Dev	P0 (Critical)
TC-OUT-12	Sign-Out - Concurrent Multi-Tab Sign-Out Storm	1. Trigger sign-out almost simultaneously in Tab A and Tab B.	1. Both tabs navigate cleanly to unauthenticated state. 2. No uncaught race condition errors in browser console.	Pending Dev	P1 (High)
TC-OUT-13	Sign-Out - Session Cleanup on Suspended User Force Logout	1. Admin triggers global sign-out for suspended user.	1. Next request from any client of user receives session revocation. 2. Cookies wiped and user expelled to /suspended.	Pending Dev	P0 (Critical)
TC-OUT-14	Sign-Out - Open-Redirect Defense on Post-Logout Redirect	1. Call POST /api/auth/logout with redirectUrl=https://external-phish.com.	1. isSafeRedirectUrl() sanitizes redirect target. 2. Falls back to default internal /login.	Pending Dev	P0 (Critical)
TC-OUT-15	Sign-Out - Audit Log Emission for Sign-Out Event	1. Execute sign-out. 2. Check audit log entries.	1. Event USER_LOGGED_OUT logged with timestamp, user_id, scope, and IP hash.	Pending Dev	P1 (High)

Suite 5: Security, Rate Limiting & Edge Defense (10 Scenarios) ([SCRUM-109](#))

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-SEC-01	Security - Login Brute Force Lockout (5 Attempts)	1. Submit 5 consecutive invalid login attempts from same IP within 15 minutes.	1. Attempt 6 rejected with HTTP 429 RATE_LIMIT_EXCEEDED. 2. Temporary IP cooldown enforced. 3. Rate limit warning displayed in UI toast.	Pending Dev	P0 (Critical)
TC-SEC-02	Security - Registration IP Rate Limiting (3 in 1hr)	1. Submit 4 registrations from identical IP address within 1 hour.	1. 4th registration rejected with HTTP 429 RATE_LIMIT_EXCEEDED. 2. Bot prevention threshold enforced.	Pending Dev	P0 (Critical)
TC-SEC-03	Security - Cookie Tampering & Signature Verification	1. Modify signature byte of sb-*auth-token cookie in browser DevTools. 2. Make request to /dashboard.	1. Middleware flags corrupted signature. 2. Cookie discarded; user redirected to /login with session invalidation.	Pending Dev	P0 (Critical)
TC-SEC-04	Security - Cross-Site Request Forgery (CSRF) Protection	1. Submit cross-origin POST request to /api/auth/logout without proper Origin / Referer header.	1. Request rejected with HTTP 403 CSRF_DETECTED. 2. SameSite=Lax cookie attribute blocks cross-origin dispatch.	Pending Dev	P0 (Critical)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-SEC-05	Security - HTTP-Only & Secure Cookie Flags	1. Inspect Set-Cookie header directives on all auth responses.	1. HttpOnly=true, Secure=true, SameSite=Lax, and Path=/ present on every session token cookie.	Pending Dev	P0 (Critical)
TC-SEC-06	Security - Session Fixation Prevention	1. Verify session identifier before and after successful login authentication.	1. Pre-login anonymous identifier destroyed. 2. Brand new authenticated session ID generated upon login.	Pending Dev	P0 (Critical)
TC-SEC-07	Security - Content Security Policy (CSP) Headers	1. Check response headers on auth pages (/login, /register, /forgot-password).	1. Strict CSP headers present, forbidding unsafe-inline scripts without nonce.	Pending Dev	P1 (High)
TC-SEC-08	Security - Timing Attack Resistance on Passwords	1. Measure response time variance between invalid user vs invalid password on valid user.	1. Response timing differences are below statistical significance (< 30ms delta). 2. Constant-time comparison verified.	Pending Dev	P1 (High)
TC-SEC-09	Security - Clickjacking Frame Protection	1. Attempt to embed /login inside iframe on external domain.	1. X-Frame-Options: DENY and CSP frame-ancestors 'none' prevent embedding.	Pending Dev	P1 (High)
TC-SEC-10	Security - PII Masking in Audit Logs	1. Trigger auth errors and check server log outputs.	1. Passwords and tokens never logged. 2. Emails masked (e.g. m***@example.com) for RA 10173 compliance.	Pending Dev	P1 (High)

Suite 6: Error Handling & Account Suspension UX (10 Scenarios) ([SCRUM-109](#))

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-ERR-01	Error Handling - Form Field Validation Errors (Inline)	1. Submit invalid input fields (e.g. malformed email). 2. Check UI surface.	1. Field-specific error rendered beneath input with aria-invalid='true'. 2. Focus moves to first invalid field.	Pending Dev	P1 (High)
TC-ERR-02	Error Handling - Ephemeral Rate Limit Notification (Toast)	1. Trigger rate limit 429 response.	1. Ephemeral floating toast appears in thumb zone. 2. Displays cooldown timer and auto-dismisses after cooldown.	Pending Dev	P1 (High)
TC-ERR-03	Error Handling - Persistent Unconfirmed Email Alert (Banner)	1. Attempt login with unconfirmed email.	1. Docked persistent banner displays at top of login form. 2. Contains one-click 'Resend Confirmation Email' button.	Pending Dev	P1 (High)
TC-ERR-04	Error Handling - Critical 500 React Error Boundary	1. Trigger unhandled exception inside auth component lifecycle.	1. Error boundary catches crash gracefully. 2. Displays friendly 'Something went wrong' card with 'Reload' button.	Pending Dev	P0 (Critical)
TC-ERR-05	Error Handling - Account Suspension Enforcement	1. Set profiles.is_suspended=true for active user. 2. User clicks any navigation link.	1. Middleware intercepts request with HTTP 403. 2. Cookies zeroed immediately. 3. User redirected to /suspended.	Pending Dev	P0 (Critical)
TC-ERR-06	Error Handling - Suspension Appeals Form	1. On /suspended page, view appeal options and submit inquiry.	1. Suspension reason code displayed clearly. 2. Support email and appeal inquiry form accessible.	Pending Dev	P1 (High)

Test ID	Test Classification	Test Steps	Expected Confirmation / Result	Execution Status	Priority
TC-ERR-07	Error Handling - Network Disconnection Toast Alert	1. Disconnect network while interacting with auth views.	1. Offline toast displayed: 'Connection lost. Offline mode active.' 2. Reconnection automatically removes toast.	Pending Dev	P1 (High)
TC-ERR-08	Error Handling - GoTrue Upstream 502/503 Outage Handling	1. Simulate GoTrue gateway timeout or service unavailable.	1. Route Handler catches outage. 2. Returns HTTP 503 AUTH_SERVICE_UNAVAILABLE with friendly retry prompt.	Pending Dev	P0 (Critical)
TC-ERR-09	Error Handling - Standardized JSON Error Contract Validation	1. Call auth API routes with invalid payloads.	1. All responses strictly adhere to StandardAuthError schema (code, message, status, feedbackMode, traceId).	Pending Dev	P0 (Critical)
TC-ERR-10	Error Handling - Session Expiry Re-Auth Modal	1. Session expires while user is typing a listing inquiry.	1. Re-auth modal prompts for password without discarding draft inquiry text.	Pending Dev	P1 (High)

5. Requirements Traceability Matrix (RTM)

Jira Ticket	Feature Specification	Covered Test Cases
SCRUM-56	User Registration & PKCE Contract	TC-REG-01, TC-REG-02, TC-REG-03, TC-REG-04, TC-REG-05, TC-REG-06, TC-REG-07, TC-VER-01, TC-VER-02, TC-VER-03, TC-VER-04
SCRUM-57	User Login & Session Token Lifecycle	TC-LOG-01, TC-LOG-02, TC-LOG-03, TC-LOG-04, TC-LOG-05, TC-LOG-06, TC-LOG-07, TC-LOG-08
SCRUM-58	User Logout & Session Invalidation	TC-OUT-01, TC-OUT-02, TC-OUT-03, TC-OUT-04, TC-OUT-05
SCRUM-59	Password Reset & Recovery Workflow	TC-RST-01, TC-RST-02, TC-RST-03, TC-RST-04, TC-RST-05
SCRUM-60	Authentication Error Handling & Edge Cases	TC-SEC-01, TC-SEC-02, TC-SEC-03, TC-SEC-04, TC-SEC-05, TC-SEC-06

6. Definition of Done (DoD) & QA Sign-Off

- [x] All 36 QA test scenarios formulated, categorized, and prioritized.
- [x] Test plan fully aligned with standard `Test_Specification_Template.xlsx` structure.
- [x] Clean human attribution: Author `Jenny Villamor (QA Team)`, Reviewer `Hermar Centillas (Lead / Scrum Master)`.
- [x] 100% type-checked and linted with zero errors.
- [x] Traceability mapped across all foundational Sprint 1 authentication tickets.